Workplace Ninjas Australia

Hi »» Ninjas!



Microsoft Entra ID Governance + Zero Trust

Technical workshop | Architecture, policy design and demo







Fred (Fouad) Lahoud

Cloud Solution Architect @ Microsoft

Strategic Thinking, Digital Strategy

Sydney, New South Wales, Australia

Microsoft

Scan to connect on LinkedIn

Fouad Lahoud

Microsoft Entra ID Governance

From ad-hoc permissions to approved, time-bound, reviewable access

OPEN

Workplace Ninjas Australia

Where do you think access is getting out of control?

A

External guests and project groups

B

Enterprise applications and direct assignments

C

Privileged roles and emergency exceptions

What is Microsoft Entra ID Governance?

It helps ensure the right people have the right access to the right resources, at the right time.

01 **Manage identity lifecycle**
Automate joiner, mover, and leaver processes.

02 **Govern access**
Request, approve, review, and expire access.

03 **Secure privileged access**
Control and review access to sensitive roles.

Outcome **Better productivity • Stronger security • Easier compliance**



Why identity governance?

Business Agility

Integration of identity solutions with enterprise apps is imperative.

Extending on-premises apps to the cloud, provides an efficient integration process for new apps.

Security Challenges

Decentralization of work and an increasing number of apps and agents can broaden the scope of finding and preventing security breaches.

Lack of control and visibility of what external users have access to is a vulnerability.

Compliance Obligations

Strict compliance requirements challenge IT admins as roles and responsibilities change constantly.

Lack of centralized view of user access or logs makes monitoring and auditing inefficient.

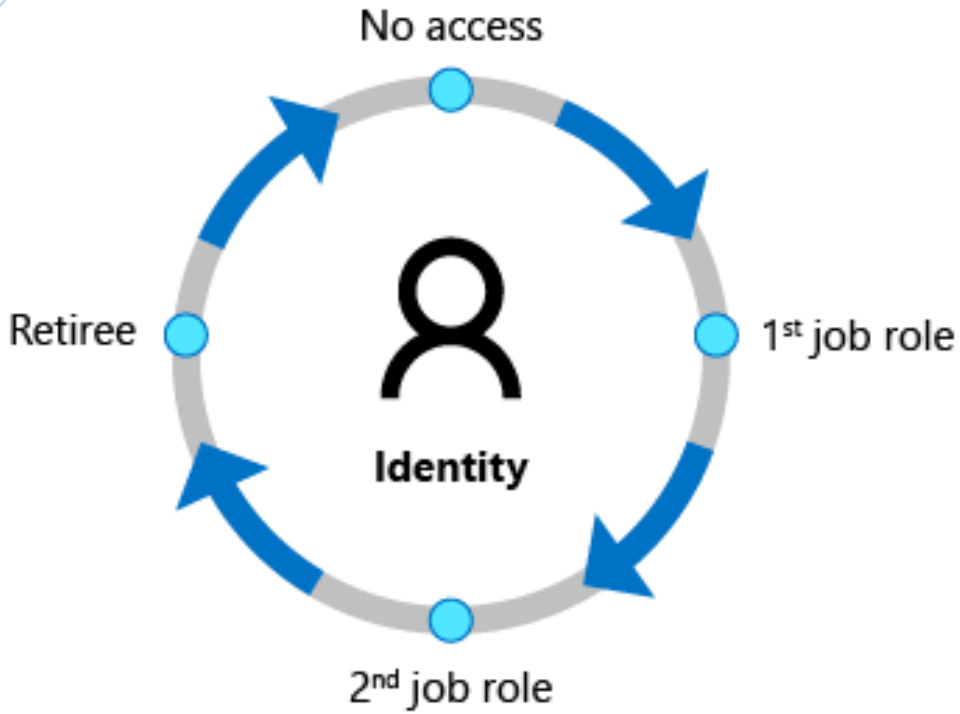


Governance makes access explainable and enforceable

- Who has access?
- What can they reach?
- Why was it granted?
- Who approved it?

- How long should it last?
- Who must review it?
- What removes it?
- What evidence remains?

Identity lifecycle starts with authoritative data



- Join: establish the identity and baseline access
- Move: recalculate access when attributes change
- Leave: disable identity and remove downstream access

The identity lifecycle answers: should this identity exist and be active?

Official Microsoft Learn diagram >

Access lifecycle is separate from identity lifecycle

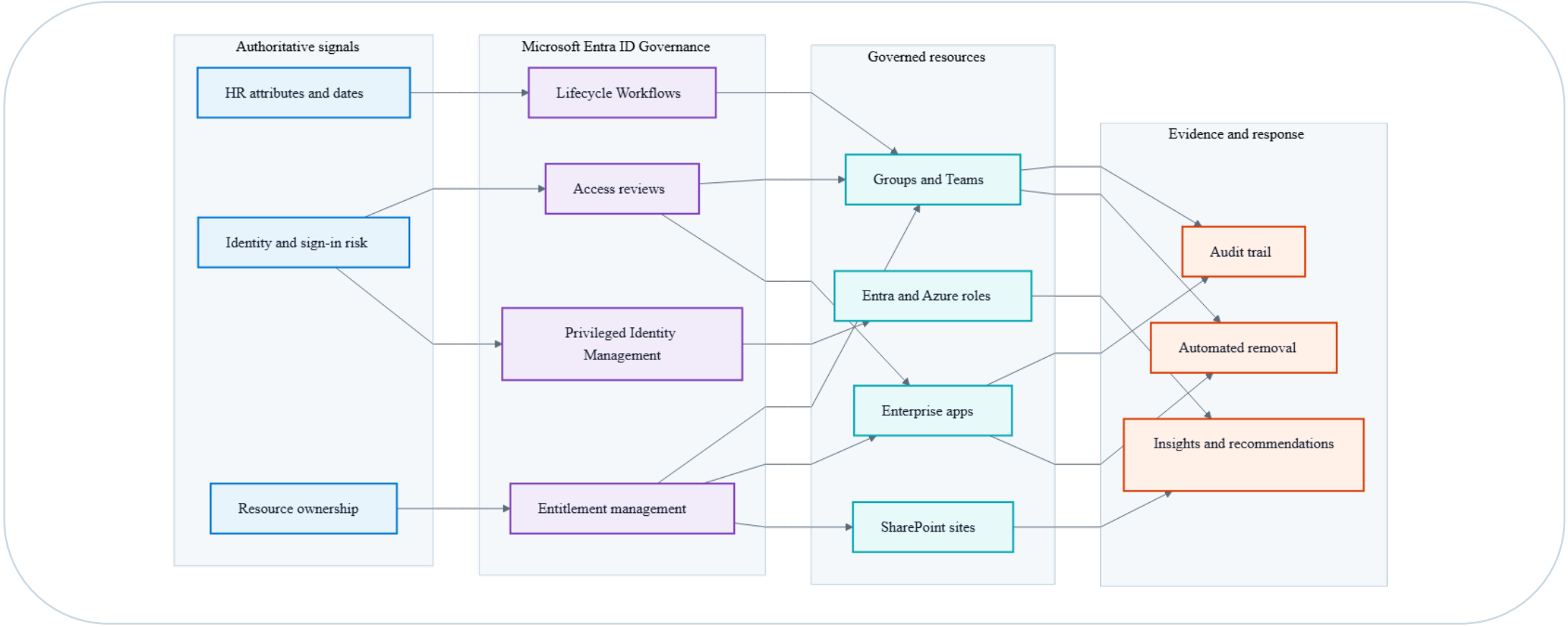
- Define the access offer and accountable owner
- Request or assign through policy
- Review continued need using current context
- Remove on denial, expiration, or lifecycle change



The access lifecycle answers: should this identity still have this resource role?

Official Microsoft Learn diagram >

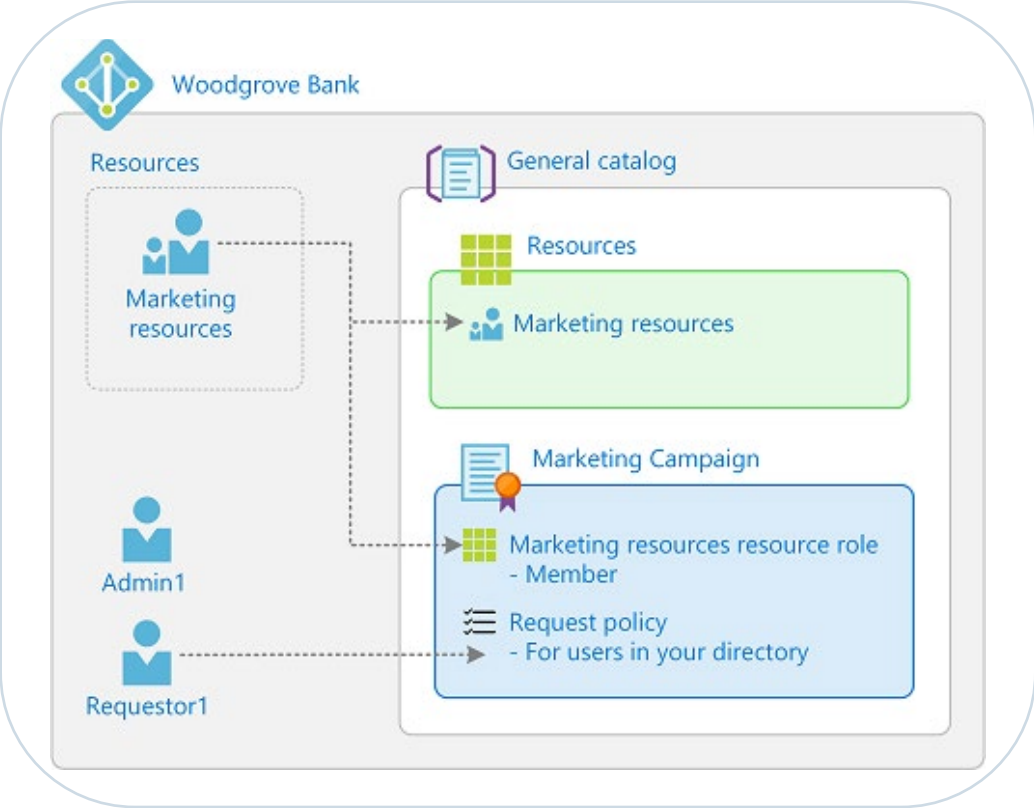
Identity Governance is the policy and evidence control plane



Signals drive governance services, governed resources, and auditable outcomes

Microsoft Learn: ID Governance overview >

Access packages connect business offers to technical resources



- Catalog contains resources
- Package contains one or more resource roles
- Policy controls requestors, approval, and lifecycle
- Assignment is the governed grant to a principal

One package can have different policies for employees and external users.

Official Microsoft Learn diagram >

Access package anatomy: four objects, four responsibilities

CATALOG

Boundary for resources, delegation, and package ownership.

PACKAGE

Business-facing access offer with a stable name and purpose.

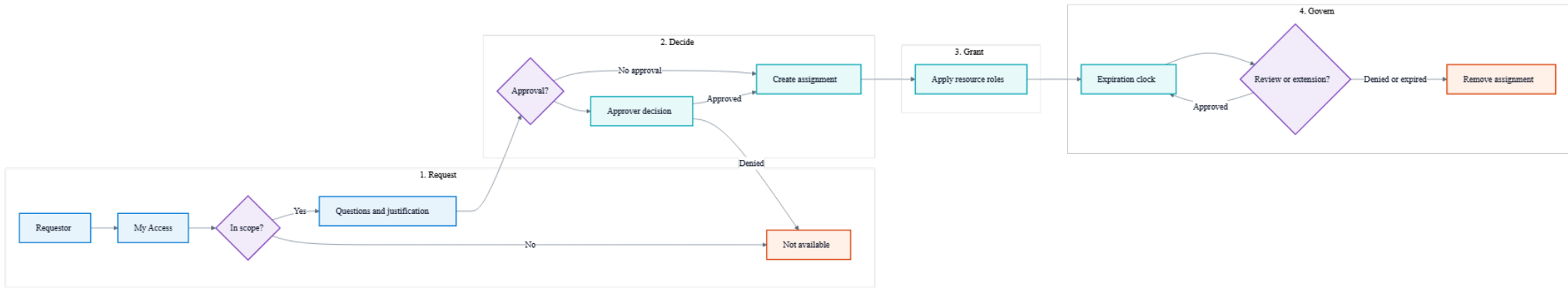
POLICY

Eligibility, questions, approval, expiration, and review.

ASSIGNMENT

The resulting principal-to-package grant with start and end.

Policy evaluation converts a request into a time-bound assignment



Original workshop flow based on entitlement management policy behavior

Microsoft Learn: Create an access package >

External access should have an explicit end-to-end lifecycle



Official Microsoft architecture visual: request, approval, collaboration, review, and expiration

Official Microsoft Learn architecture >

Catalog design determines delegation and blast radius

Design choice	Use when	Guardrail
Central catalog	A platform team owns shared resources	Limit package-manager role assignment
Business catalog	A function owns resources and approvals	Document owner and review cadence
Project catalog	Short-lived collaboration needs isolation	Set archive and cleanup criteria
Externally visible catalog	Partners must discover an offer	Restrict connected organizations and policy scope

Request policy design starts with population and risk

Control	Lower-risk internal access	Higher-risk external access
Requestor scope	Selected users or groups	Connected organizations or explicit sponsors
Questions	Business reason	Project, sponsor, data classification
Approval	Manager or resource owner	Sponsor plus resource owner
Expiration	Role-aligned duration	Short fixed duration
Review	Periodic for sensitive resources	Recurring with auto-apply

Approval patterns trade speed for independent assurance

ONE STAGE

Use one accountable owner when risk and ownership are clear.

TWO STAGE

Combine relationship validation with resource authorization.

FALLBACK

Define alternate approvers so requests do not stall.

ESCALATION

Set decision timeouts and an operational follow-up path.

Expiration is the baseline; extension and review are new decisions

ASSIGNMENT LIFECYCLE

- Fixed days or fixed end date
- Optional user extension request
- Assignment ends without approval
- Resource roles are removed

REVIEW LIFECYCLE

- Choose reviewer and recurrence
- Provide decision context
- Define no-response behavior
- Apply results automatically where appropriate

A request, an extension, and a review are three separate control events.

Demo topology: four actors, one governed assignment



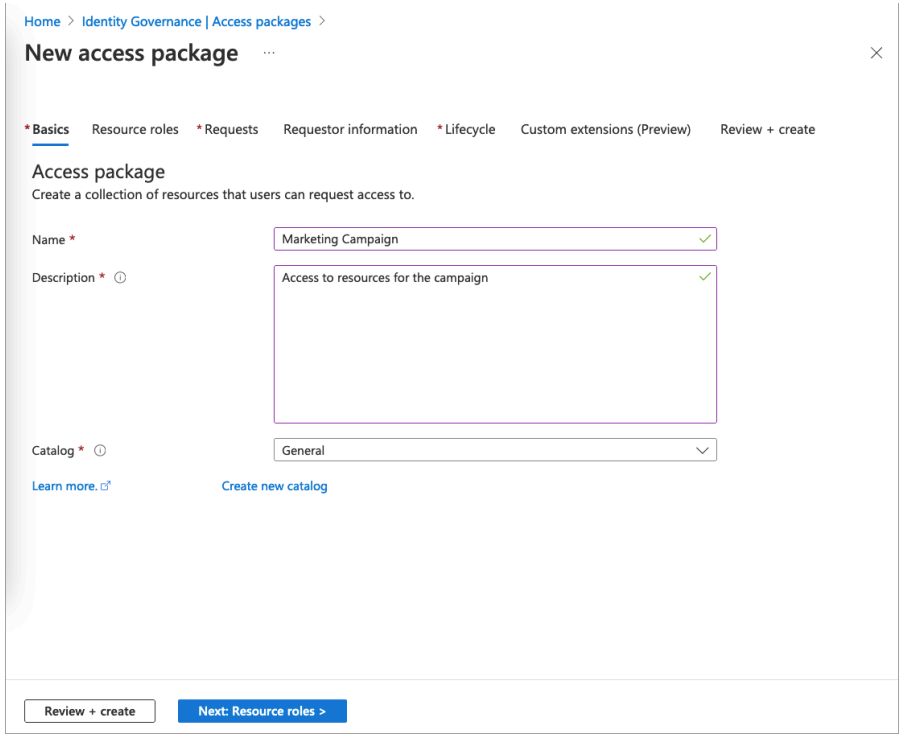
- Governance Admin creates package and policy
- Vendor User requests through My Access
- Project Owner approves the request
- Project-Vendors-Access receives membership
- Use separate browser profiles for each persona

Pre-stage identities and group; create the package live.

Official Microsoft Learn scenario >

Checkpoint 1: create the business-facing access offer

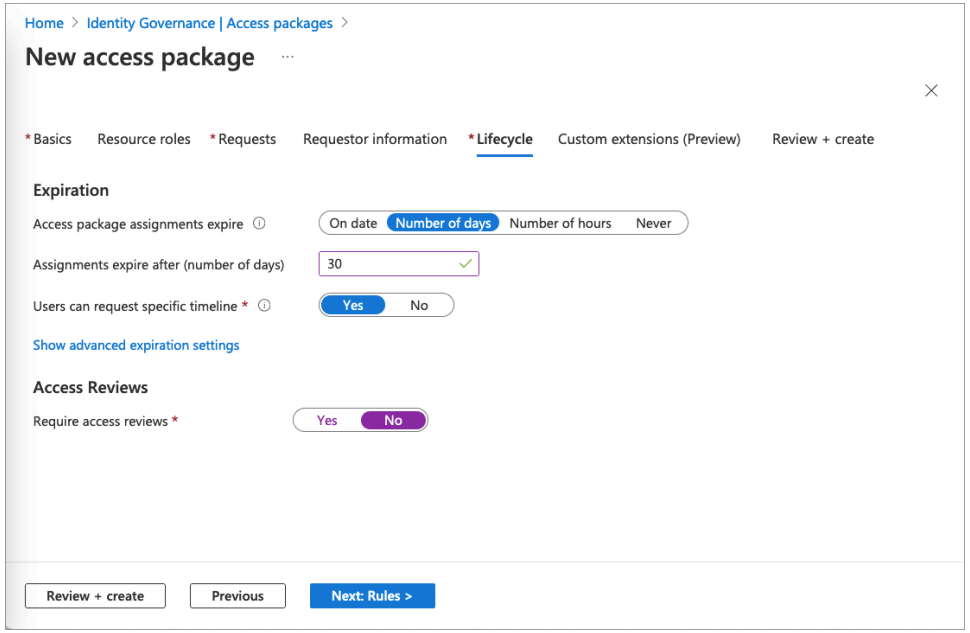
- Name: Project Vendor Access - 14 days
- Choose the project or external-access catalog
- Write a description requestors can understand
- Add Project-Vendors-Access as Member



Narrate the business purpose before the technical resource.

Official Microsoft Learn screenshot >

Checkpoint 2: make time and review part of the policy



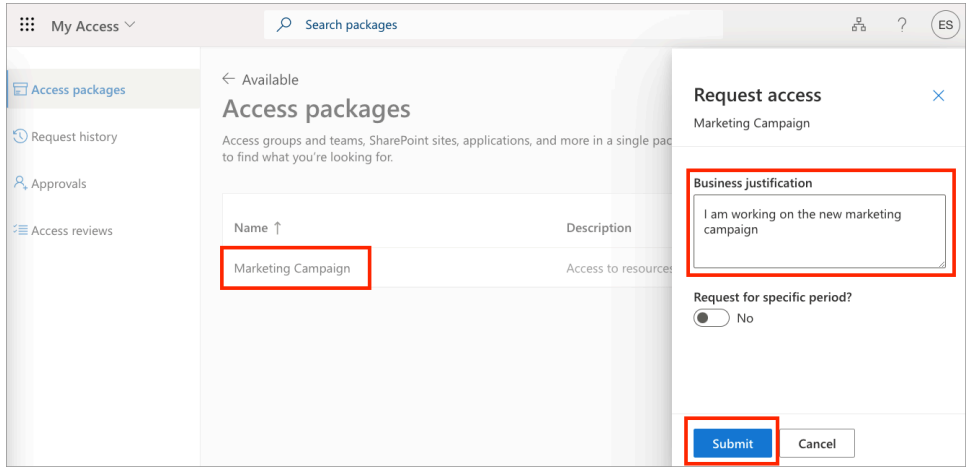
- Limit assignments to 30 days
- Decide whether users can request extension
- Configure recurring review for active assignments
- Set reviewer, frequency, and result behavior

Expiration is deterministic; review adds a fresh human or policy decision.

Official Microsoft Learn screenshot >

Checkpoint 3: the requestor sees a governed product

- Open My Access as Vendor User
- Select the package and enter justification
- Submit and observe Pending approval
- Switch to Project Owner and approve
- Verify assignment and group membership



The request trail replaces ad-hoc email and chat approvals.

Official Microsoft Learn screenshot >

Design challenge: which policy best fits this vendor?

A vendor needs a sensitive project app for six weeks. The sponsor owns the relationship; the app owner owns data risk.

A

Sponsor approval, no expiration, quarterly review

B

Sponsor plus app-owner approval, 14-day expiration, extension with justification

C

Self-approval, six-week expiration, no review

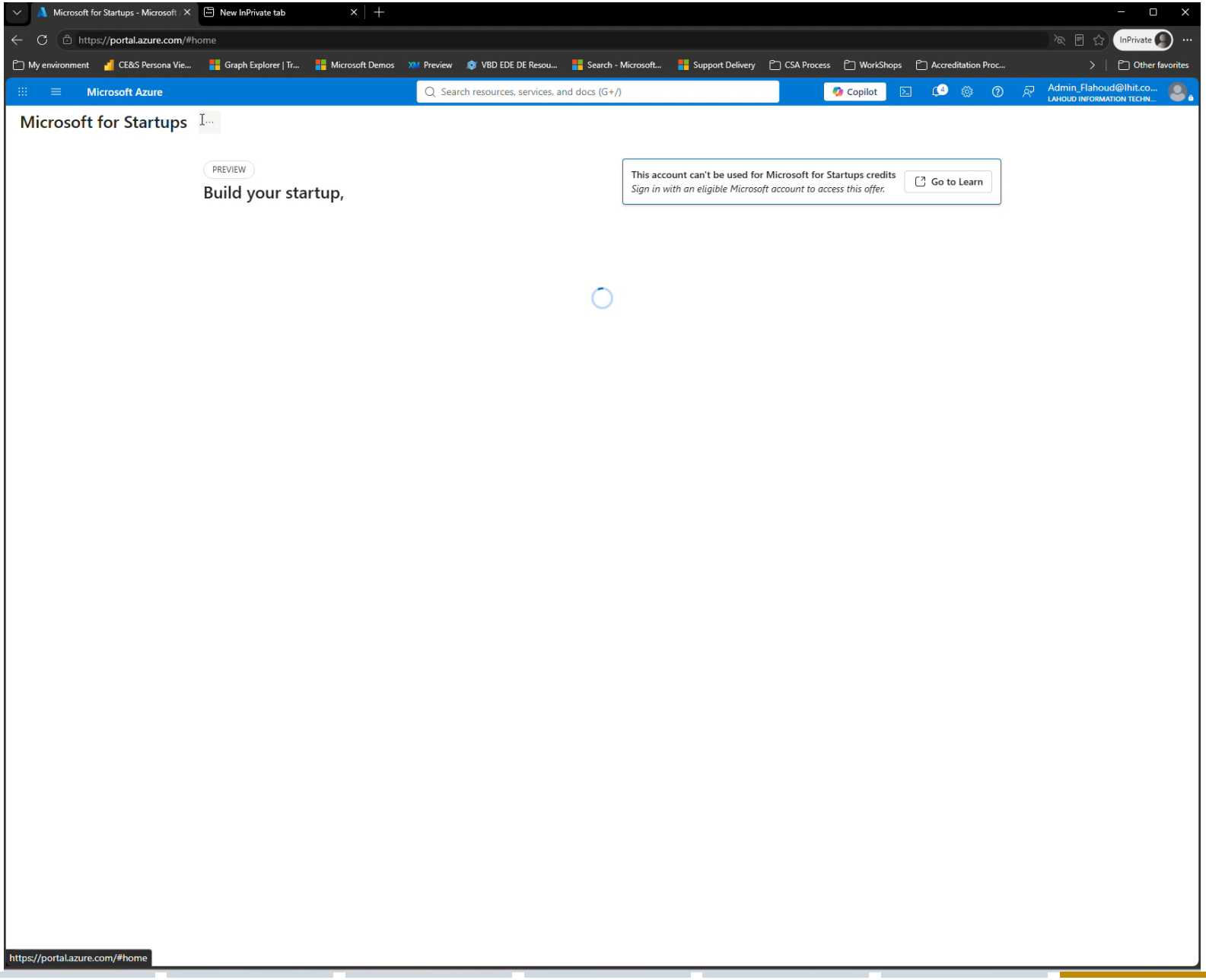
Click any option in Slide Show mode to reveal the recommended design.

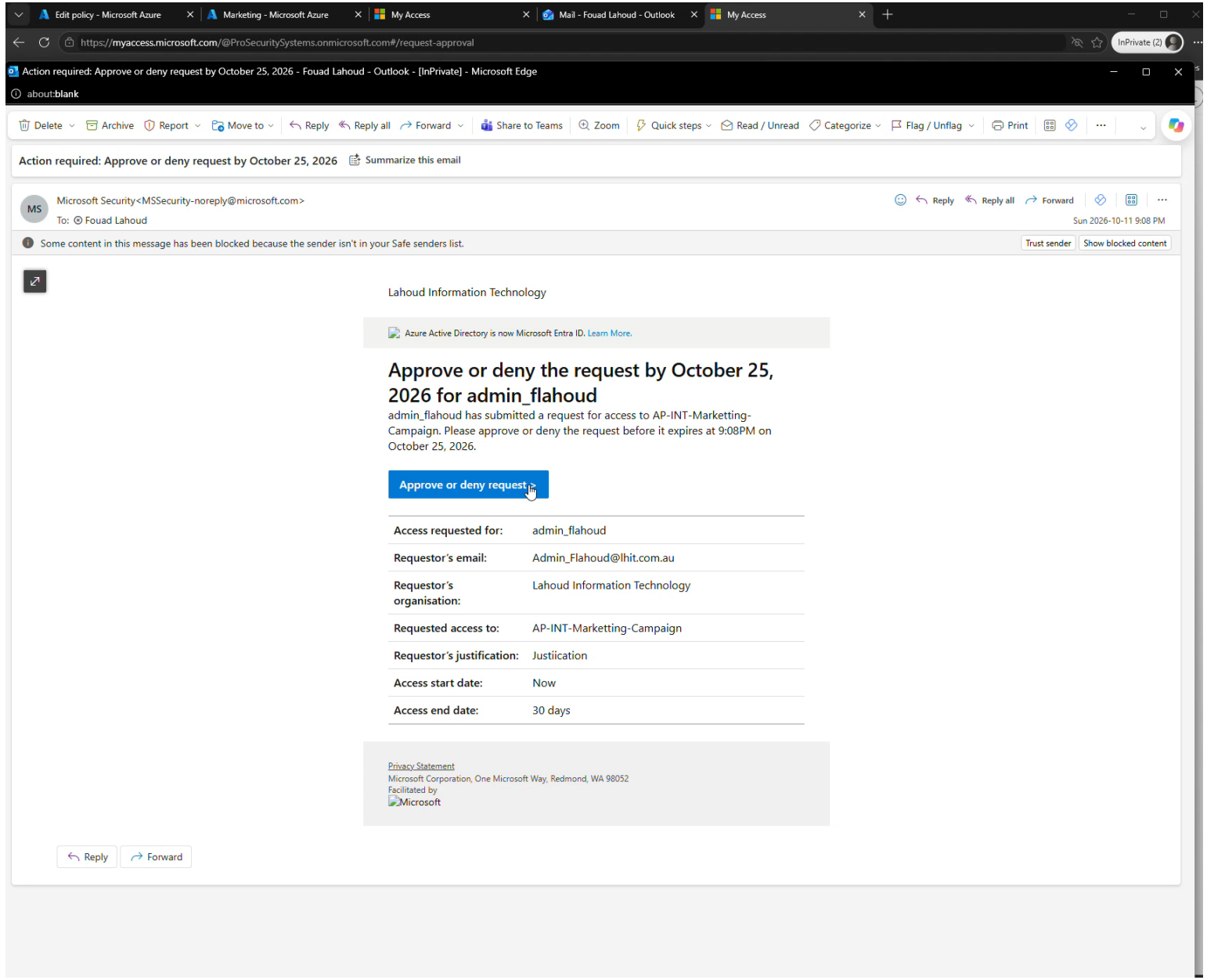
Recommended: B - separate relationship, resource, and time decisions

Sponsor + app owner | 14 days | justified extension

- Sponsor validates the external relationship
- App owner validates the resource and data risk
- Short duration limits stale access and blast radius
- Extension creates a fresh, auditable decision
- Recurring review is still appropriate if assignments can persist

< BACK TO CHALLENGE


Microsoft for Startups - Microsoft
New InPrivate tab
https://portal.azure.com/#home
InPrivate
My environment
CE&S Persona Vie...
Graph Explorer | Tr...
Microsoft Demos
Preview
VBD EDE DE Resou...
Search - Microsoft...
Support Delivery
CSA Process
WorkShops
Accreditation Proc...
Other favorites
Microsoft Azure
Search resources, services, and docs (G+/)
Copilot
Admin_Flahoud@lhit.co...
LAHOUD INFORMATION TECHN...
Microsoft for Startups
PREVIEW
Build your startup,
This account can't be used for Microsoft for Startups credits
Sign in with an eligible Microsoft account to access this offer.
Go to Learn
https://portal.azure.com/#home


Edit policy - Microsoft Azure
Marketing - Microsoft Azure
My Access
Mail - Fouad Lahoud - Outlook
My Access
https://myaccess.microsoft.com/@ProSecuritySystems.onmicrosoft.com#/request-approval
InPrivate (2)
Action required: Approve or deny request by October 25, 2026 - Fouad Lahoud - Outlook - [InPrivate] - Microsoft Edge
about:blank
Delete
Archive
Report
Move to
Reply
Reply all
Forward
Share to Teams
Zoom
Quick steps
Read / Unread
Categorize
Flag / Unflag
Print
Action required: Approve or deny request by October 25, 2026
Summarize this email
MS
Microsoft Security<MSSecurity-noreply@microsoft.com>
To: Fouad Lahoud
Reply
Reply all
Forward
Sun 2026-10-11 9:08 PM
Some content in this message has been blocked because the sender isn't in your Safe senders list.
Trust sender
Show blocked content
Lahoud Information Technology
Azure Active Directory is now Microsoft Entra ID. Learn More.
Approve or deny the request by October 25, 2026 for admin_flahoud
admin_flahoud has submitted a request for access to AP-INT-Marketting-Campaign. Please approve or deny the request before it expires at 9:08PM on October 25, 2026.
Approve or deny request
Access requested for: admin_flahoud
Requestor's email: Admin_Flahoud@lhit.com.au
Requestor's organisation: Lahoud Information Technology
Requested access to: AP-INT-Marketting-Campaign
Requestor's justification: Justiication
Access start date: Now
Access end date: 30 days
Privacy Statement
Microsoft Corporation, One Microsoft Way, Redmond, WA 98052
Facilitated by
Microsoft
Reply
Forward

Access reviews are a scheduled decision system



- Define scope, reviewer, recurrence, and duration
- Notify reviewers and present decision context
- Capture approve, deny, or no-response outcome
- Apply results and retain evidence

Launching a review is not the control; applying the outcome is.

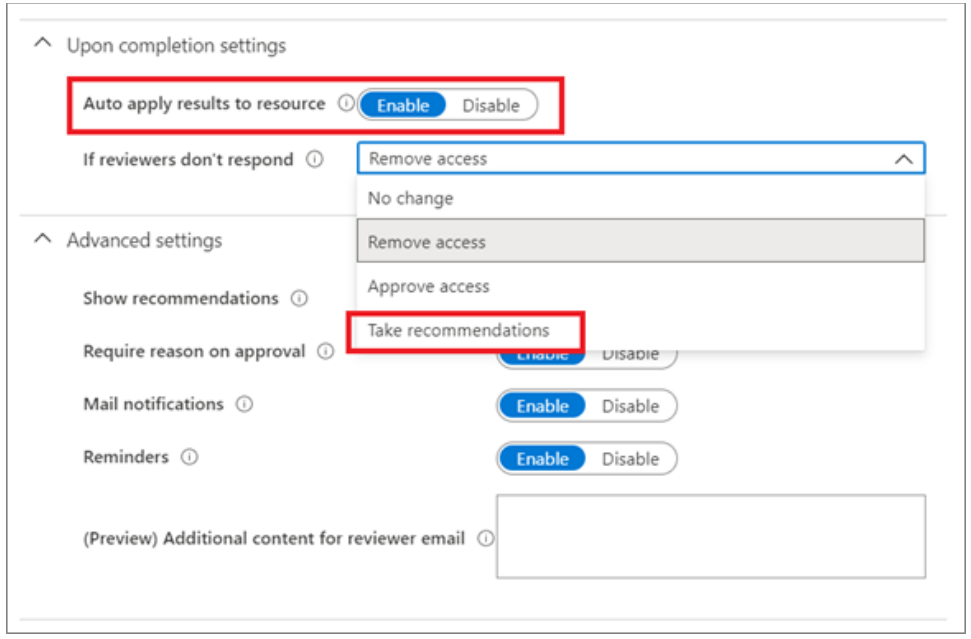
Official Microsoft Learn diagram >

Reviewer guidance should translate signals into a decision

Signal	Interpretation	Recommended action
Active business sponsor	Relationship is still valid	Continue to resource need check
No recent sign-in	Possible stale or unused access	Validate before approving
Project ended	Business purpose no longer exists	Deny and remove
Owner cannot identify user	Accountability failure	Deny or escalate
High-risk resource	Stronger assurance required	Use independent reviewer

Automation closes the gap between review and remediation

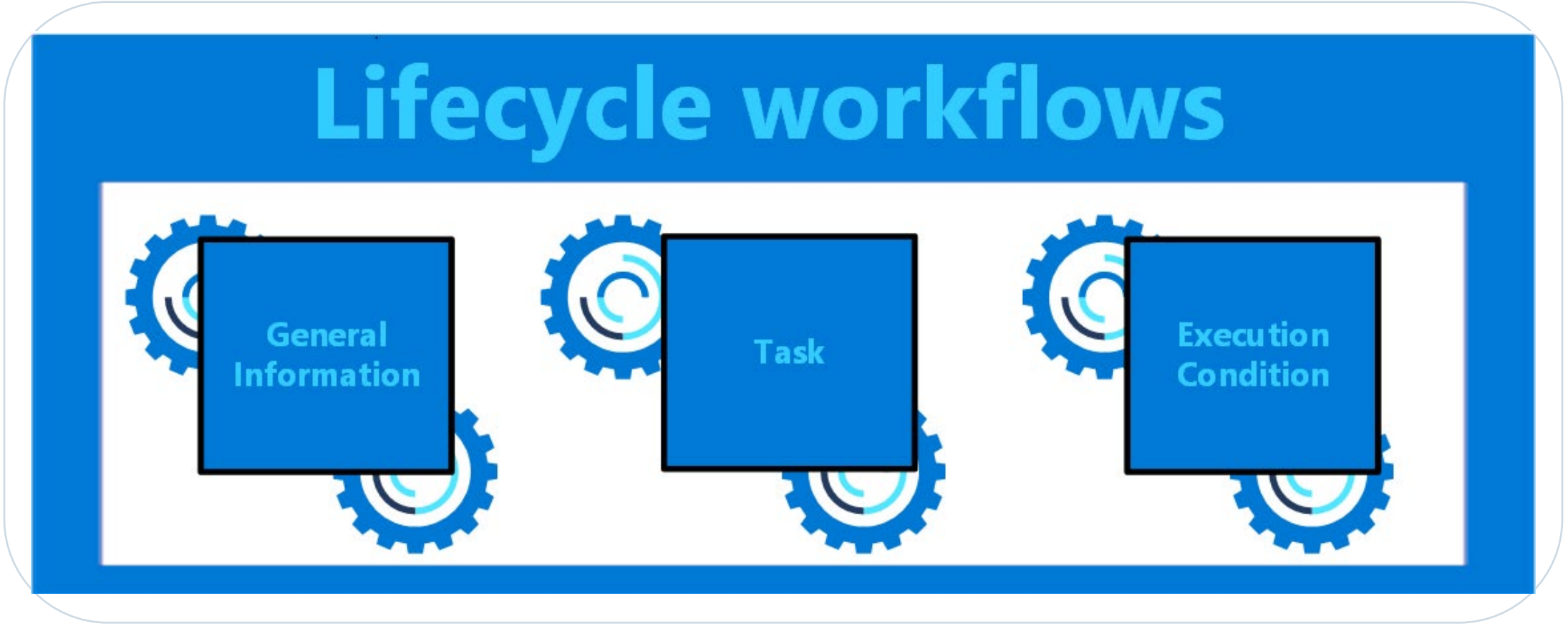
- Enable auto-apply where policy permits
- Choose deny or remove behavior deliberately
- Define fallback for reviewers who do not respond
- Monitor failed result application



Automate predictable outcomes; escalate ambiguous ones.

Official Microsoft Learn screenshot >

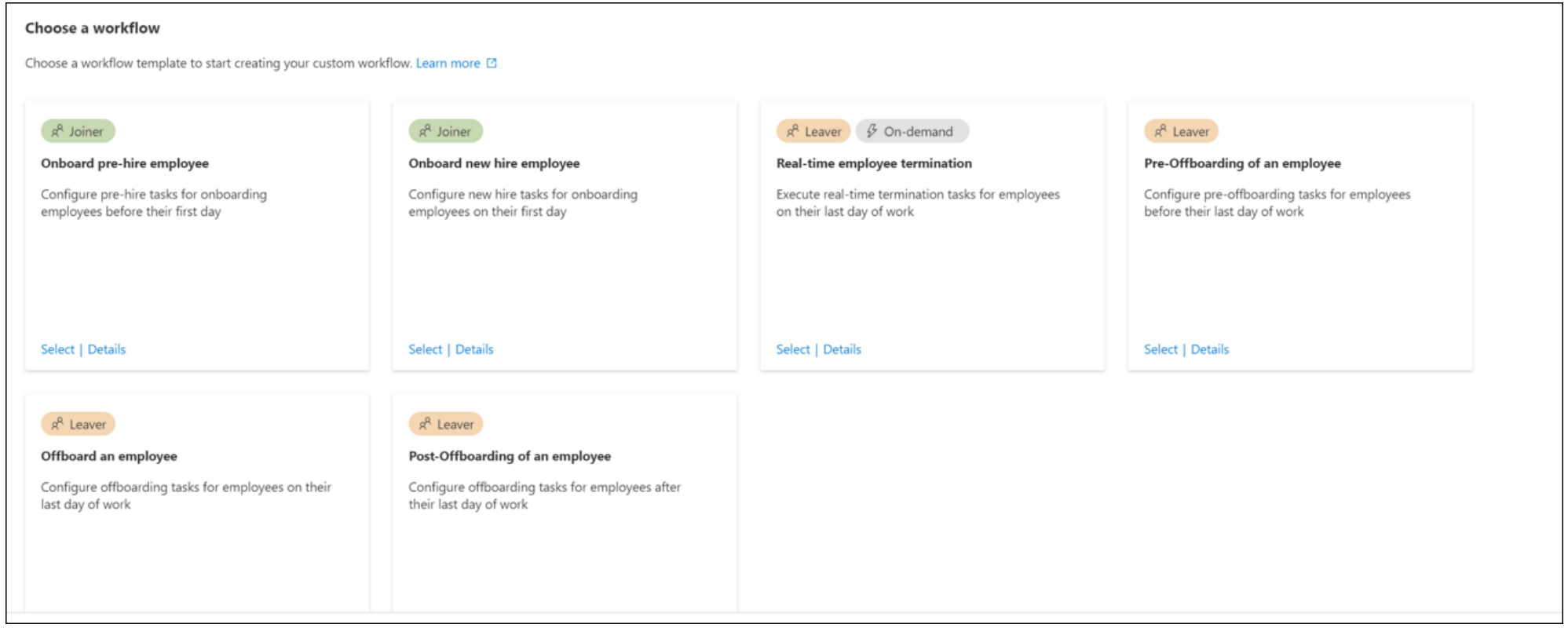
Lifecycle workflows execute tasks around joiner, mover, and leaver events



Official Microsoft Learn workflow model

Official Microsoft Learn diagram >

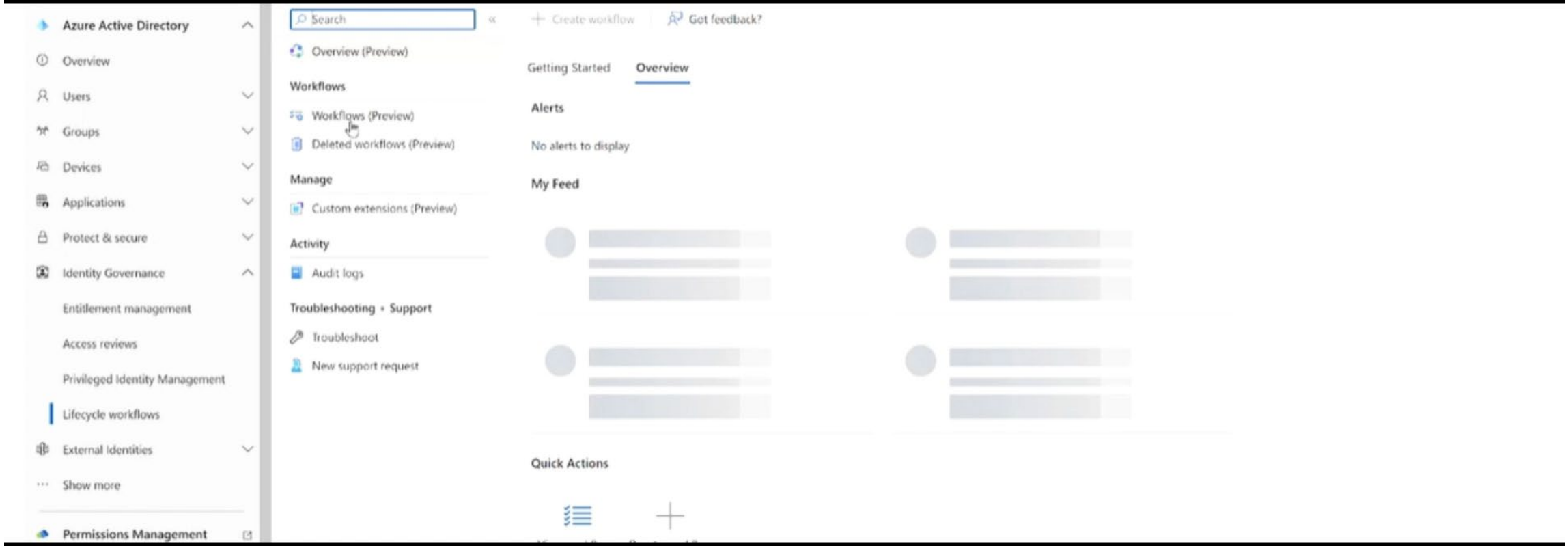
Workflow engineering requires testable scope and observable execution



Template -> scope -> tasks -> on-demand test -> schedule -> monitor

Official Microsoft Learn diagram >

Demo


Azure Active Directory
Overview
Users
Groups
Devices
Applications
Protect & secure
Identity Governance
Entitlement management
Access reviews
Privileged Identity Management
Lifecycle workflows
External Identities
Show more
Permissions Management
Search
Overview (Preview)
Workflows
Workflows (Preview)
Deleted workflows (Preview)
Manage
Custom extensions (Preview)
Activity
Audit logs
Troubleshooting + Support
Troubleshoot
New support request
Create workflow
Got feedback?
Getting Started
Overview
Alerts
No alerts to display
My Feed
Quick Actions

Microsoft Security

Workplace Ninjas Australia

Microsoft Zero Trust Workshop

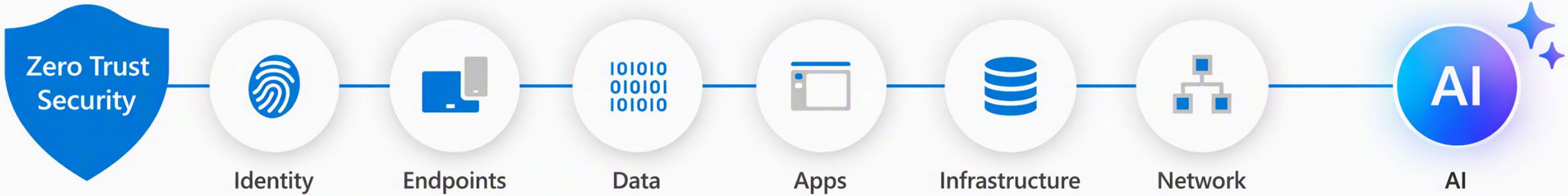
Why a Zero Trust Workshop?

Implementing security on Zero Trust principles can be overwhelming - it's hard to know where to start, what to enable first, or how to measure progress. The Workshop replaces that uncertainty with a clear, data-driven plan.

The Workshop helps you

- Assess your current security posture
- Define a roadmap from real assessment data
- Align to Microsoft security solutions
- Track progress with a continuous plan

Microsoft Zero Trust Three Principles *and Seven foundational pillars*



Verify explicitly

Always validate (**authenticate** and **authorize**) all available data points including

- User identity and location
- Device health
- Service or workload context
- Data classification
- Anomalies

Use least privileged access

To help secure both data and productivity, **limit user** access using

- Just-in-**time** (JIT)
- Just-**enough**-access (JEA)
- Risk-based **adaptive** polices
- Data protection against **out of band** vectors

Assume breach

Minimize blast radius for breaches and **prevent lateral movement** by

- **Segmenting access** by network, user, devices, and app awareness.
- **Encrypting** all sessions end to end.
- **Use analytics** for threat detection, posture visibility and improving defenses

PILLAR 01

Identity

The primary Zero Trust control plane.

01

WHAT IT PROTECTS

Users, admins, service accounts, and workload identities.

KEY MOVES

- Phishing-resistant, passwordless MFA
- Conditional Access on every sign-in
- Least privilege with PIM & access reviews
- Identity governance: lifecycle & provisioning

IN THE ROOM

IAM team · ID Governance · enterprise app developers

QUICK WIN Turn on phishing-resistant MFA and block legacy authentication.

PILLAR 02

Devices

Healthy, compliant endpoints - everywhere.

02

WHAT IT PROTECTS

Laptops, mobile, IoT, partner-managed and cloud-hosted endpoints.

KEY MOVES

- Enroll & manage with Intune
- Enforce device compliance policies
- Gate access on device health via Conditional Access
- Continuously monitor endpoint risk

IN THE ROOM

MDM architect & admin · security ops · Conditional Access admin

QUICK WIN Require a compliant device for access to your most sensitive apps.

PILLAR 03

Data

Protect what matters, wherever it lives.

03

WHAT IT PROTECTS

Documents, email, and databases - structured and unstructured.

KEY MOVES

- Discover & classify sensitive data
- Apply sensitivity labels with Purview
- Encrypt and enforce usage rights
- Stop leaks with Data Loss Prevention

IN THE ROOM

Information protection architects · compliance officers · data platform admins

QUICK WIN Auto-label your top three sensitive document types.

PILLAR 04

Network

Segment, encrypt, and remove implicit trust.

04

WHAT IT PROTECTS

Network traffic, segmentation boundaries, and connectivity.

KEY MOVES

- Segment to shrink the blast radius
- Secure app access with Global Secure Access
- Encrypt traffic end to end
- Replace flat, implicitly-trusted zones

IN THE ROOM

Network operations · IAM · application & workload owners

QUICK WIN Pilot Global Secure Access for one internal app.

PILLAR 05

Infrastructure

Harden multicloud and hybrid workloads.

05

WHAT IT PROTECTS

Compute and storage across multicloud and hybrid estates.

KEY MOVES

- Continuous posture management with Defender for Cloud
- Harden VM, container & storage configs
- Just-in-time and least-privilege access
- Baseline patching and drift control

IN THE ROOM

Infrastructure security · endpoint security · application developers

QUICK WIN Enable Defender for Cloud and watch your secure score.

PILLAR 06

Security Operations

Detect and respond across the business.

06

WHAT IT PROTECTS

Threat protection, detection, and response - everywhere.

KEY MOVES

- Unify signal with Defender XDR
- Centralise detection in Sentinel (SIEM)
- Automate response & playbooks
- Proactive threat hunting, 24x7

IN THE ROOM

SOC analysts · incident-response managers · security engineers

QUICK WIN Onboard key log sources to Sentinel and turn on XDR.

PILLAR 07

AI

Govern AI with the same rigour as everything else.

07

WHAT IT PROTECTS

AI models, agents, MCP servers, and the datasets behind them.

KEY MOVES

- Inventory AI agents & resources
- Give agents governed identities & least privilege
- Protect training & grounding data
- Monitor AI usage for risk & misuse

IN THE ROOM

AI platform / dev lead · data governance · SOC · security architect

QUICK WIN Inventory your AI agents and apply access governance.

Three tools, one mission

1

Workshop tool

WEB APP

Plan your deployment across all seven pillars, prioritise tasks in a First-Then structure, and auto-generate summaries and implementation plans.

Open the tool ›

2

Assessment

POWERSHELL MODULE

A read-only scan of your tenant that produces scores, gaps, and recommendations per pillar - the technical backbone of the workshop.

Get started ›

3

Framework Explorer

REFERENCE

Interactive mindmaps of all 7 pillars, 36 functional areas, and 720 tasks - your map of the whole framework.

Explore the hub ›

Running the assessment

1. **Install** — PowerShell 7 · Install-Module ZeroTrustAssessment
2. **Connect** — Connect-ZtAssessment · consent as Global Admin (first run)
3. **Run** — Invoke-ZtAssessment · read-only, data stays local
4. **Review** — Open the HTML report - Identity, Devices, Network, Data tabs

[Step-by-step setup guide ›]

Facilitator notes

Run it ahead of time

Large tenants can take 24+ hours - never run it live.

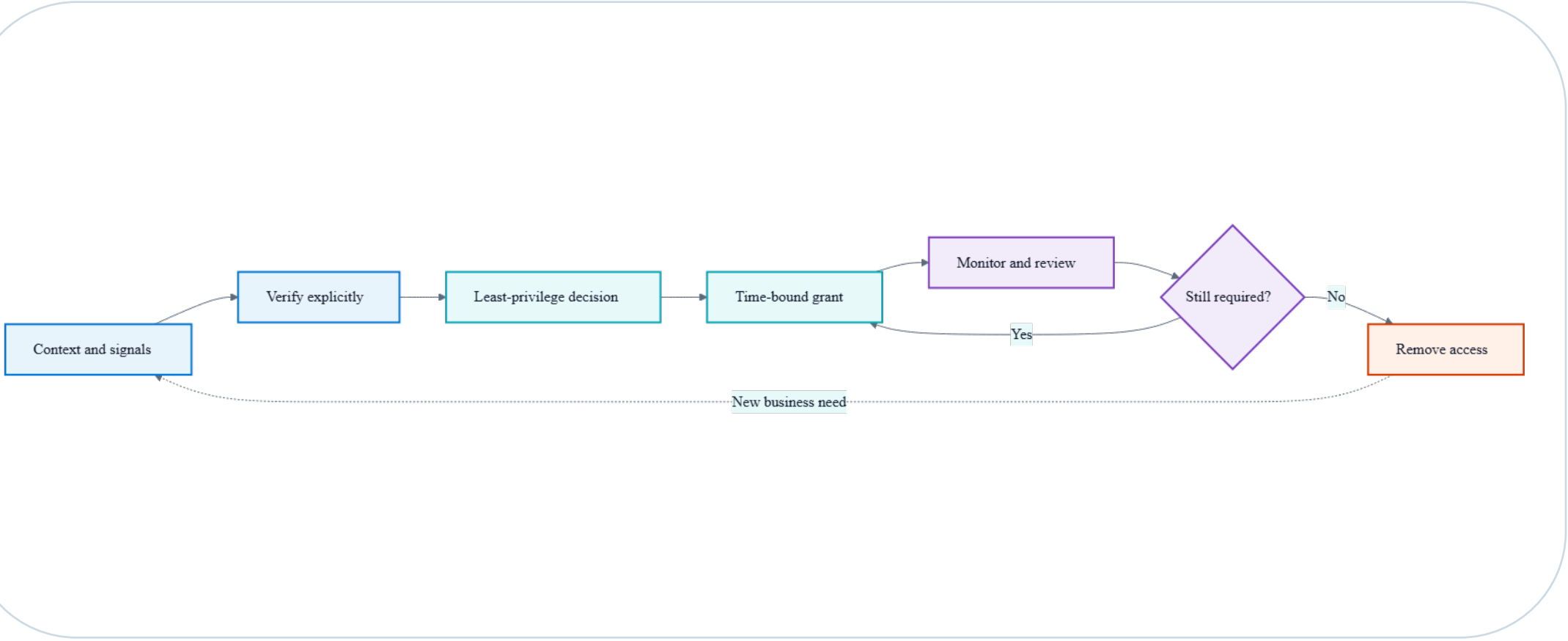
Confirm roles first

Global Admin to consent; Global Reader for later runs.

Handle it as sensitive

The report exposes tenant detail - share only with authorised staff.

Zero Trust identity is a continuous governance loop

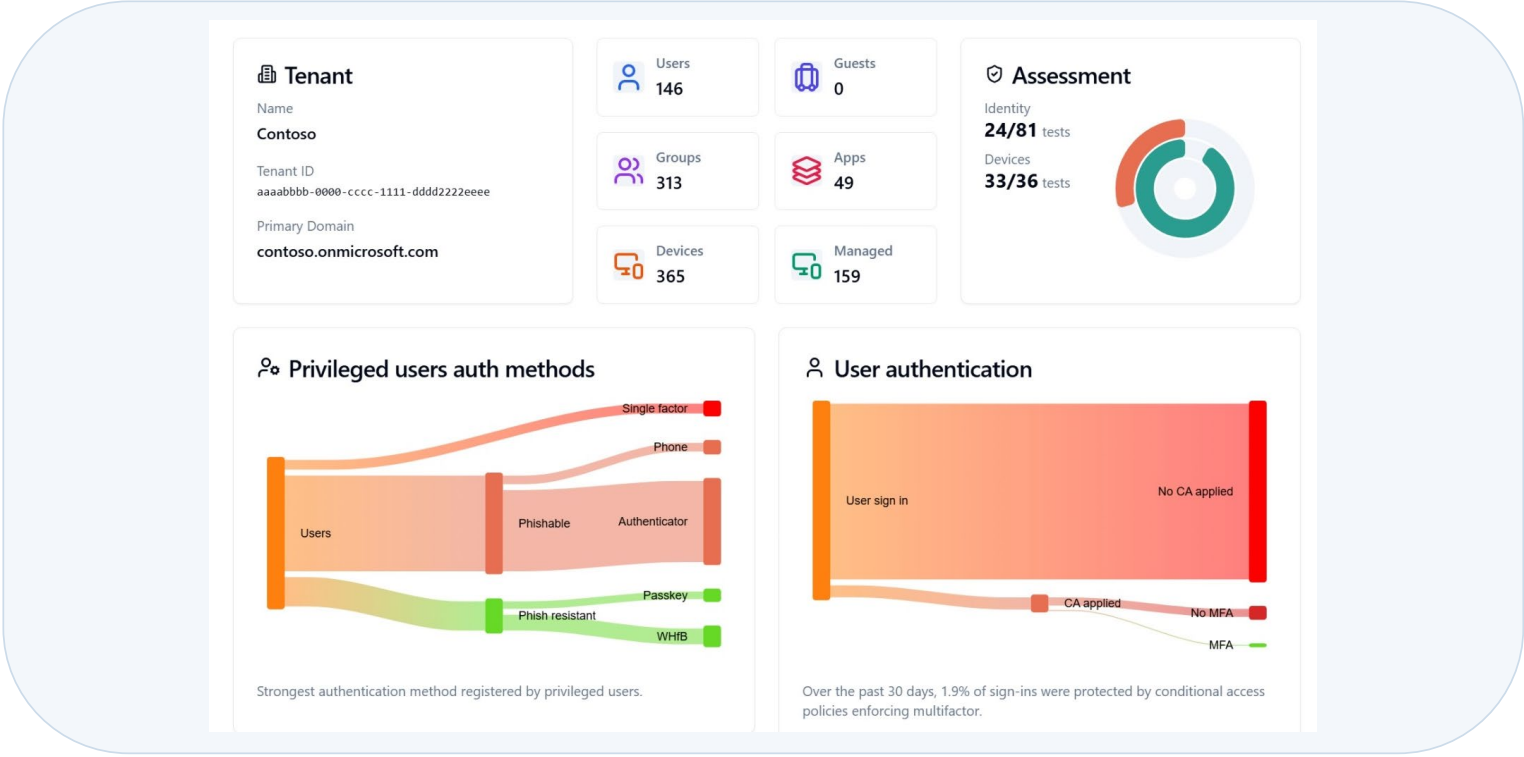


Original workshop diagram based on Microsoft Zero Trust principles

Microsoft Learn: Zero Trust identity >

Start with evidence, not a security-score assumption

- Baseline the tenant before a security change.
- Find gaps across connected services.
- Prioritize risk, user impact and effort.
- Rerun to verify the intended outcome.



Official Microsoft Learn sample report, cropped. UI varies by version.

Missing visibility is a gap to investigate, not evidence that a control passed.

Microsoft Learn: assessment overview

Microsoft Learn: risk, impact and cost

Run an assessment as a controlled six-step process

01 | PLAN

Approve tenant, services, access and report retention.

02 | INSTALL

Use PowerShell 7 and a tested module version.

03 | CONNECT

Consent once; confirm the tenant in each service.

04 | RUN

Export to a protected folder and monitor completion.

05 | REVIEW

Validate coverage, results, evidence and priority.

06 | ACT + RERUN

Assign owners; change safely; verify with fresh data.

Microsoft Learn: run the assessment

Microsoft: assessment source

Use a clean PowerShell 7 session and a tested release

POWERSHELL 7 | CURRENT USER

```
$PSVersionTable.PSVersion

Install-Module ZeroTrustAssessment `
  -Scope CurrentUser -RequiredVersion 2.6.0

Get-InstalledModule ZeroTrustAssessment
```

- The workshop is verified against 2.6.0.
- Review repository and dependency prompts.
- Check the installed version before connecting.

Expected: PowerShell major version 7 and module version 2.6.0.

Microsoft Learn: run the assessment

Published module: version 2.6.0

Confirm the intended tenant across the service sign-ins

POWERSHELL 7 | DELEGATED SIGN-IN

```
$tenantId = Read-Host "Tenant ID or domain"
Connect-ZtAssessment -TenantId $tenantId

Get-MgContext |
  Select-Object TenantId, Account
```

- Approve Graph consent in the authorized first run.
- Expect multiple cloud-service sign-ins.
- Confirm the selected Azure subscriptions.

Expected: the correct tenant context and required service connections.

Microsoft Learn: run the assessment

Microsoft: assessment source

Write each run to a new, protected local folder

POWERSHELL 7 | READ-ONLY ASSESSMENT

```
$runDate = Get-Date -Format yyyyMMdd-HHmmss
$reportPath = Join-Path $HOME `
  "ZeroTrustReports\Workshop-$runDate"

Invoke-ZtAssessment -Path $reportPath `
  -DisableTelemetry -ShowLog
```

- All seven current report pillars run by default.
- Monitor progress; record warnings and gaps.
- Large tenants can take more than 24 hours.

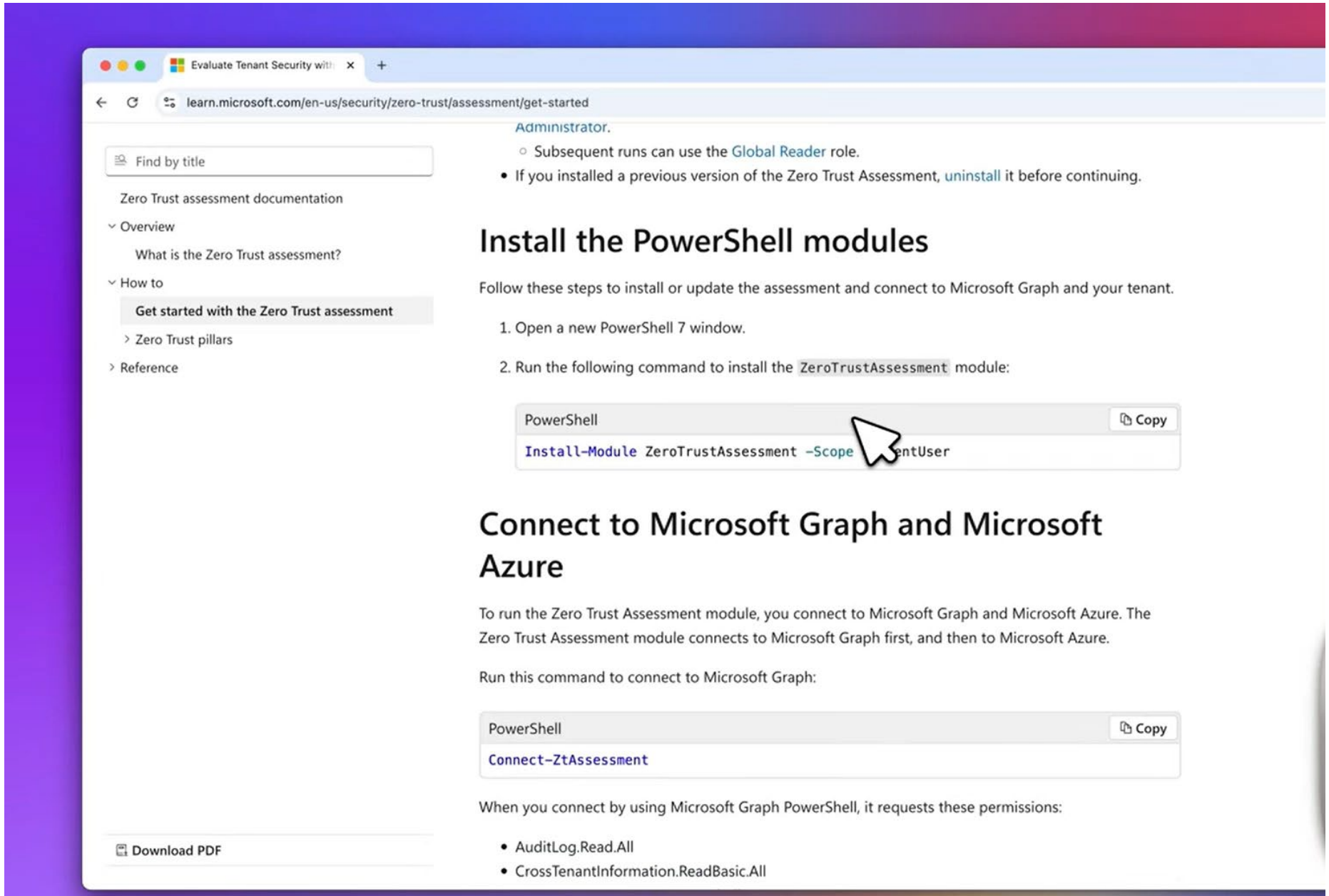
Expected report: $reportPath\ZeroTrustAssessmentReport.html

Local exports are sensitive. -DisableTelemetry opts out of tenant-ID telemetry.

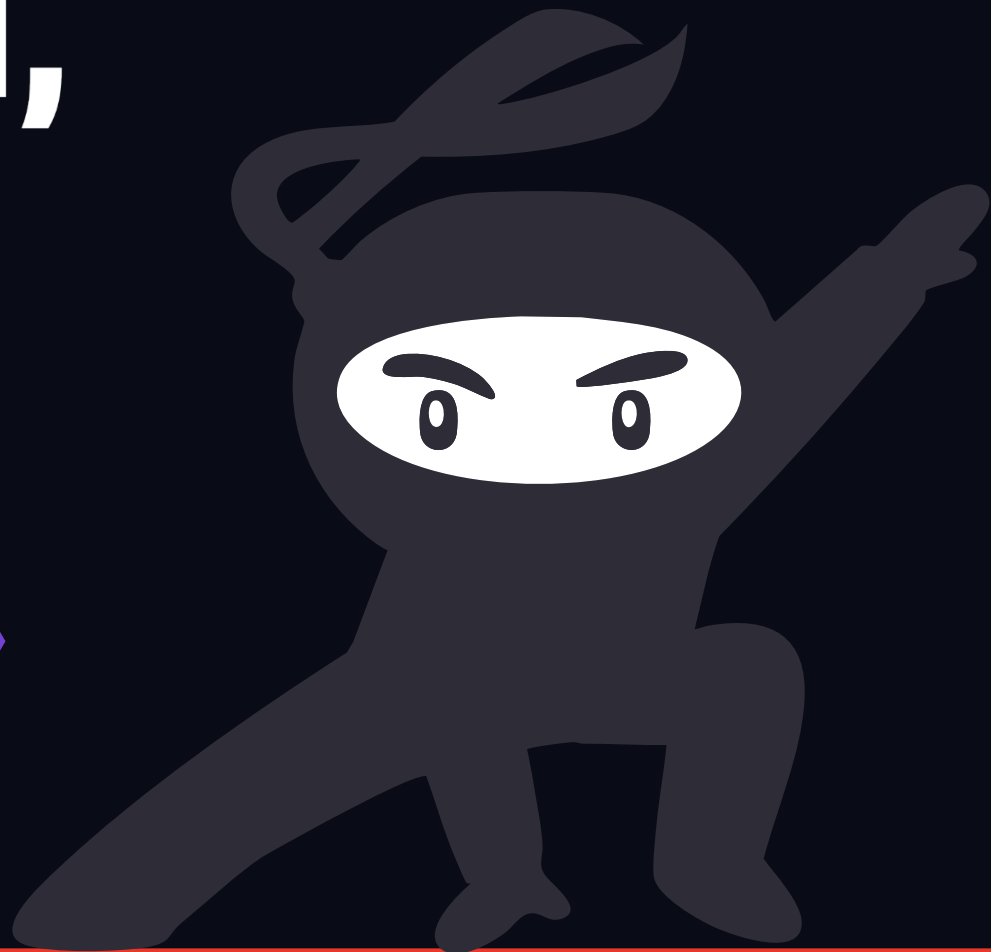
Microsoft Learn: run the assessment

Microsoft: assessment source

Demo: Microsoft Zero Trust Assessment



Thank You, Ninjas!



Thank you, Sydney sponsors!

glueck kanja

DEVICIE

eG Innovations